https://www.nist.gov/cybersecurity-and-privacy/how-do-i-create-good-password

National Institute of Standards and Technology
U.S. Department of Commerce

Information technology (https://www.nist.gov/information-technology)

Cybersecurity and privacy (https://www.nist.gov/cybersecurity-and-privacy)

How Do I Create a Good Password?

And what else can I do to secure my online accounts?



Passwords are one of the least secure ways of protecting your online information.
Credit: JMiks/Shutterstock

You may have come to the NIST website looking for tips on how to make a more secure password — and you will find that in this article. But experts have long considered passwords to be insecure. Even the longest, most complex passwords can be guessed, stolen or otherwise compromised.

As new ways to verify your identity have emerged, cybersecurity experts at encourage you to avoid relying on passwords whenever possible. But passw ı inescapable. What should you do when you are required to create one?

NIST maintains digital identity guidelines (https://pages.nist.gov/800-63-4/sp800-63b.html#appA). These widely used guidelines include a ton of useful advice for IT professionals on how to protect and verify the identity of the users of their website or application.

But if you are not an IT pro, and you just want some advice on how to make your online accounts more secure, read on. In this article, we'll explain why passwords are inherently insecure. If you must use one, we'll give you some tips to make your passwords easier to use and harder to steal. We'll also explain how you can increase your account security by using tools such as multifactor authentication.

How do hackers steal passwords?

One of the most common ways that hackers steal a password is by tricking you into giving it to them. This is called phishing.

For example, an attacker might send you a link to a website that looks identical to a website you trust. Even if you're careful and knowledgeable, it can be difficult to detect a fake website.

In a phishing attack, the fake website is actually controlled by an attacker. It will ask you to log in, just like the real website, and when you do, you will have unknowingly given away your username and password.

That's just one example of the many ways that someone, anywhere in the world, might get you to send them your password. It doesn't matter how long or complicated your password is if an attacker is able to trick you into sending it to them.

But I've never been phished. Are my passwords safe to use?

Even without phishing, many passwords can be easily guessed. In general, people are bad at choosing unique passwords.

"The worst password I can think of is 'password' or '12345,'" says Ryan Galluzzo (https://www.nist.gov/blogs/cybersecurity-insights/authors/ryan-galluzzo), who leads NIST's Digital Identity Program. "Those are at the top of an attacker's list for potential attacks." They are also two of the most common passwords.

You might think your password isn't that bad — that someone who was trying to log into your account wouldn't get enough tries to guess it exactly. That's right to some extent; login pages for most websites only let you guess a handful of wrong passwords before you are locked out.

But attackers don't usually guess passwords through the public login page. The guessing starts after a website has had a data leak and the attacker gets their hands on a copy of all the encrypted passwords.

The passwords can be decrypted by guessing them correctly. And once an attacker has an offline copy of the encrypted passwords, they can make as many guesses as they like.

With a modern PC, an attacker can attempt to decrypt 100 billion passwords per second. That's a lot of guesses! If you printed out 100 billion passwords on single-spaced, double-sided pieces of paper, the sheets would fill about four semitrucks.

But even with all those guesses, hackers will want to be as efficient as possible, so the first thing they will likely try is passwords exposed from previous data breaches. After a big data breach, these exposed passwords become easy to find online. This is another weakness of passwords — if the same password is used for multiple websites, a compromised password at one website could lead to a compromise at every website where that password is used.

Is my password already compromised?

According to the Identity Theft Resource Center (https://www.idtheftcenter.org/post/2024-annual-data-breach-report-near-record-compromises/), there were more than 3,000 data breaches in 2024, potentially exposing hundreds of millions of online accounts. Because password breaches are not uncommon, some of your passwords could already be on publicly available lists. You can check if any of the passwords you use have been compromised by using a tool like Have I Been Pwned? (https://haveibeenpwned.com/) This free website lets you see if your email address has been part of a data breach. Almost everyone has been "pwned" once.

Now, you may be asking yourself, what should I do then? If passwords are insecure, how do I protect my online accounts? Here are NIST's recommendations.

The first thing you should do is add multifactor authentication.

What is multifactor authentication?

If the app or website you're using requires a password to log in, you should check if it gives you the option to turn on something known as multifactor authentication, or MFA. MFA provides an extra layer of security that can help protect a user's account even if their password is compromised.

MFA comes in many forms, such as USB dongles, authenticator apps, push notifications or text message codes. When MFA is turned on, a hacker would need to not only compromise your password but also gain control of the second factor. This second factor is much harder to compromise since it is typically something physically in your possession, like your phone. Some MFA methods are more secure than others (text codes are particularly vulnerable), but in general, having more than one factor for authentication makes your accounts more secure.

If you're frustrated by passwords, a new, more convenient technology is poised to replace them entirely. It's called a passkey.

What is a passkey?

Passkeys are a new way to prove your identity online. They work by storing a private digital key on a device you already carry around, such as your phone. If you use your phone to set up a passkey for a website, you'll be able to log in as easily as you unlock your phone — by entering your PIN or using facial recognition. Unlike passwords, passkeys can't be easily stolen through phishing and don't require memorization.

The passkey is different for every login, so even if an attacker could get the secret code off your device, they wouldn't be able to use it for any other websites. And passkeys aren't just for phones; they can also be used through laptops, dongles or even some web browsers.

How does a password manager work?

For accounts that require passwords, NIST experts highly recommend that you use a password manager.

Password managers are apps that make the process of creating and using passwords easier by generating long, complex passwords and storing them securely so you don't have to remember or write them down. They solve many of the frustrations you might

have with passwords since they make highly unique passwords that you can access from almost any device.

However, password managers still require a login. Since that login protects all your passwords, it's important to choose a password manager that supports MFA to ensure that it is as secure as possible.

If you can't use MFA, a passkey or a password manager and you need to come up with a password on your own, NIST researchers have some recommendations.

What is NIST's guidance for passwords?

The most important part of a good password is its length. Every additional character dramatically increases the number of guesses an attacker would need to try. For example, a one-character password made from lowercase letters would take at most 26 guesses. Adding a second character increases that number to 26 times 26, which is 676 guesses. An eight-character password would take about 200 billion guesses. That's way too many for a human to guess, but remember that a modern laptop can comfortably make 100 billion guesses *per second,* so eight characters is not very secure at all.

NIST guidance recommends that a password should be at least 15 characters long. At 100 billion guesses per second, it would take a computer more than five hundred years to guess all the possible combinations of 15 lowercase letters.

That may seem like a lot of characters to memorize, but you can make it easier for yourself by making what Galluzzo calls a "passphrase." A passphrase combines multiple real words together to create something that's easier to invent and remember.

For example, "cassette lava baby" is 18 characters long, memorable, and random enough to be hard to guess. (Of course, we urge you not to use this passphrase now that we've created this example!)

While that may make you feel secure, remember that if an attacker gains access to an offline database with your password encrypted in it, they can make as many guesses as they need and they have many tricks to make the guessing process faster. Even long passwords will ultimately fall to a dedicated attacker.

Should my password have special characters and numbers?

NIST no longer recommends that passwords require special characters and numbers. But that doesn't mean you can't include them in your own passwords. Ultimately, adding these extra complexities will make the password harder to guess, but it's more important for the password to be long, so that should be your main priority. That said, you may not have a choice, as many websites still require numbers, capital letters and special characters, but that may change as more websites adopt NIST's new guidance.

Are passwords going extinct?

In an ideal world, we could stop using passwords entirely in favor of more reliable technologies, but they're not going away any time soon.

"It's going to be a long road to completely kill the password," says Galluzzo. "There are lots of great alternatives out there, but you're always going to be constrained by what technology people have available." Almost anyone can type a password on almost any machine. That versatility has made them difficult to get away from entirely.

To secure your online accounts, remember these three main tips:

1. Set up multifactor authentication. Passkeys are a great option.
2. Use a password manager.
3. If you must make a password, make sure it's at least 15 characters long. A passphrase can help you come up with something long and memorable.

To sum up, if you must create a password, don't choose "password"! And more importantly, don't use a password alone — take advantage of other steps to secure your account, such as multifactor authentication. These additional steps are the true key for securing your account as best as possible.

For more resources on this topic, please see NIST's original guidance (Special Publication 800-63B (https://pages.nist.gov/800-63-4/sp800-63b.html)), which contains a list of references (https://pages.nist.gov/800-63-4/sp800-63b.html#references) as well as an

appendix (https://pages.nist.gov/800-63-4/sp800-63b.html#appA) discussing the challenges of memorizing secrets.

Information technology (https://www.nist.gov/topic-terms/information-technology), Cybersecurity and privacy (https://www.nist.gov/topic-terms/cybersecurity-and-privacy) and Identity and access management (https://www.nist.gov/topic-terms/identity-and-access-management)

Created April 28, 2025, Updated August 20, 2025

Was this page helpful? (https://www.nist.gov/webform/page_feedback?page=https://www.nist.gov/cybersecurity-and-privacy/how-do-i-create-good-password&page_title=How Do I Create a Good Password?&source_entity_type=node&source_entity_id=1880881)